COMP 3920

DATABASE SYSTEMS 1

PATRICK GUICHON

TODAY'S OBJECTIVES

- Apply database access control and administer user accounts, roles and privileges

ROOT

- Should we use the MySQL `root` account for everything?

http://androidfannetwork.com/wp-content/uploads/2013/04/gotroot__03091.1262926081.600.600.jpg

MS SQL USERS AND PRIVILEGES

- What Login have we used so far?

```
sa
```

- System Administrator
- Can do EVERYTHING!

ROOT AND SA

- `root` and `sa` have too much power!
- `root` only has access from localhost

- Why create new users?
- Limit dangerous commands.
- Only let people see what they ***need*** to see.

http://pomes.info/img/unix-practical-jokes-2.jpg

MYSQL USERS

- Consist of a username and IP address
  - `root@'localhost'`
  - `'Mary'@'192.168.0.105'`
  - `'Mark'@'10.10.25.222'`
  - `'Susan'@'%'`

http://pomes.info/img/unix-practical-jokes-2.jpg

MS SQL USERS AND PRIVILEGES

- Login
  - Login and Password
- User
  - Create 1 User for each Database the Login needs access to
  - Possibly multiple Users per Login
- Privileges
  - Users have privileges on Database Objects like Tables

MS SQL USERS AND PRIVILEGES

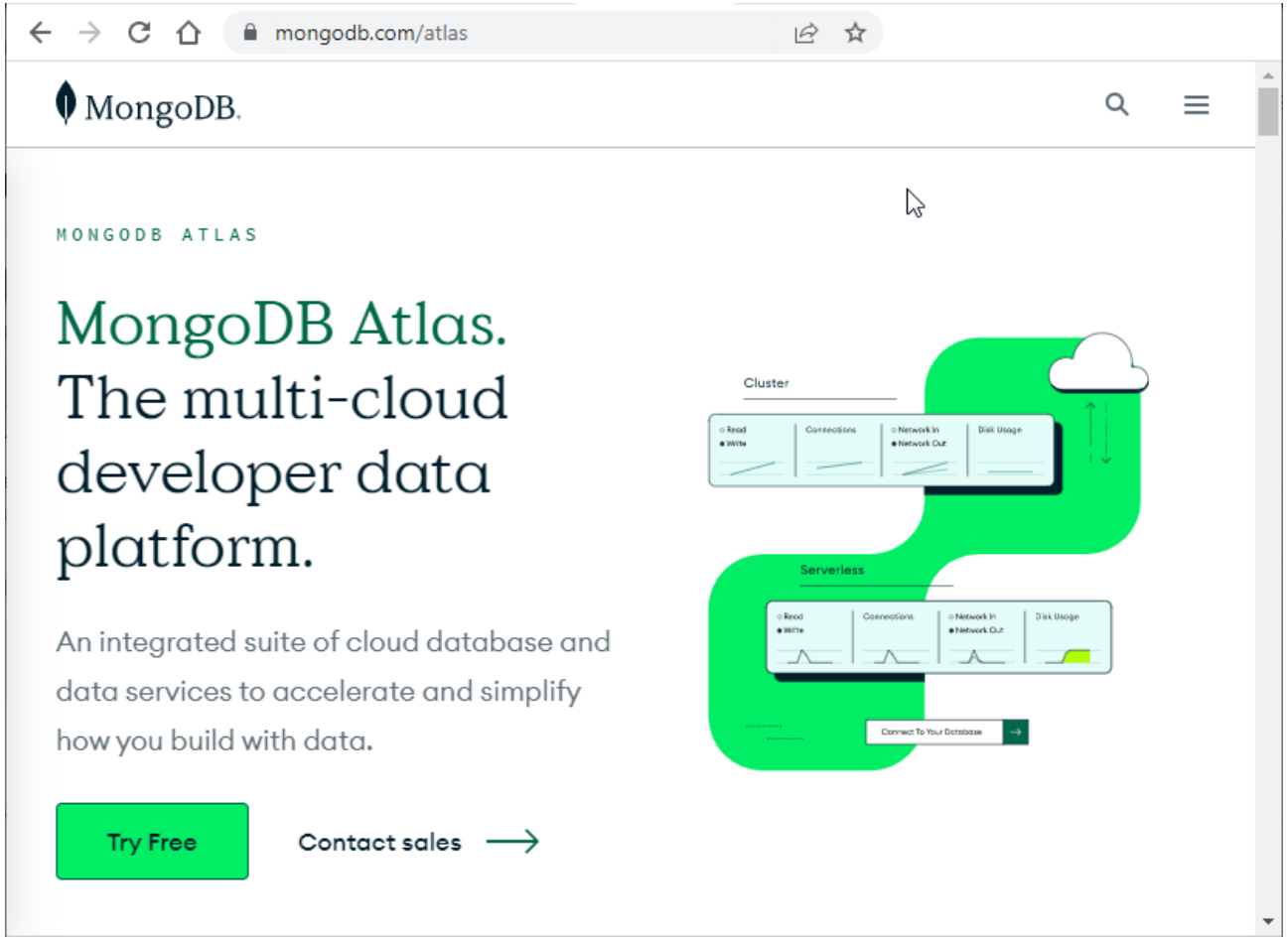
- CREATE LOGIN **Patrick_G** WITH PASSWORD='Awesome!';
- USE Bookstore;
- CREATE USER **Patrick_G_Bookstore** FOR LOGIN **Patrick_G**;
- GRANT **SELECT, INSERT** ON Books TO **Patrick_G_Bookstore**;

ACCESS CONTROL

- SELECT (non-sensitive info) SELECT (including sensitive info)
- INSERT/UPDATE (non-critical) INSERT/UPDATE (potentially dangerous)
- DELETE (non-critical) DELETE (potentially dangerous)
- CREATE, DROP, ALTER (DB designer)
- SELECT, INSERT, UPDATE, DELETE,
  CREATE, ALTER, DROP, INDEX (WordPress)
- SELECT, SHOW VIEW, RELOAD, EVENT,
  REPLICATION CLIENT, PROCESS, TRIGGER (Backup User)
- ALL (DB Admin)

MONGODB ATLAS

- Used MongoDB Atlas?



HOSTING

- Used Heroku or Qoddi?

https://leimao.github.io/images/blog/2022-03-12-Heroku-App-Host/heroku.svg
https://blog.qoddi.com/content/images/2021/11/800px-transparent-logo-1.png
https://render.com

SQL INJECTION POLL

Do you know what SQL Injection is?

A. Yes, I've written code to prevent SQL Injection

B. Yes, but I haven't written any code to prevent SQL Injection

C. No, I don't really know much about SQL Injection.

https://pollev.com/patrickguichon985

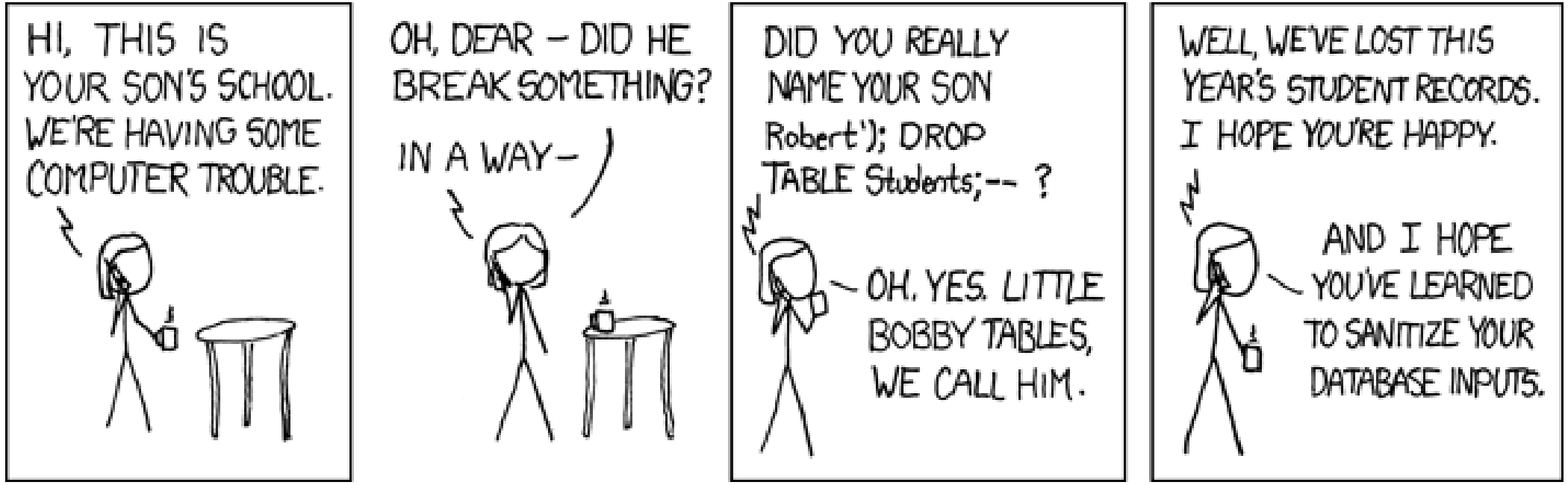
https://www.kratikal.com/blog/wp-content/uploads/2020/06/how-to-prevent-sql-injection-attack.png

SQL INJECTION

- Video
- Demo

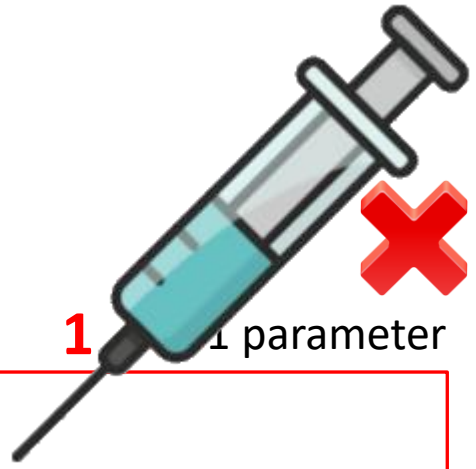
https://favpng.com/png_view/sql-injection-vulnerability-database-attack-png/eCya2RaE

XKCD



https://xkcd.com/327/
https://imgs.xkcd.com/comics/exploits_of_a_mom.png

SQL INJECTION



- **Bad Way** (Vulnerable)

```
connection.query(
"SELECT email FROM users
WHERE username = '" + username + "'"),
```

1 parameter

- **Good Way** (Protected)

```
connection.query("SELECT email
FROM users WHERE username = ?",
 username);
```

1

2

2 parameters

Reference: https://planetscale.com/blog/how-to-prevent-sql-injection-attacks-in-node-js

https://spng.subpng.com/20190802/ysp/kisspng-hypodermic-needle-injection-syringe-hand-sewing-ne-namratha-chetan-android-apps-appnaz-com-5d4502c6905286.6199219215648037825912.jpg
https://nordvpn.com/wp-content/uploads/2020/02/sql-injection_1200x675.jpg
https://banner2.cleanpng.com/20180428/cte/kisspng-firewall-computer-icons-computer-software-computer-5ae51203958981.7837017115249617956125.jpg
https://gallery.yopriceville.com/var/resizes/Free-Clipart-Pictures/Arrows-PNG/Check%20Mark%20Symbol_Transparent_PNG_Clip_Art_Image.png?m=1507172105
https://banner2.kisspng.com/20171127/be2/check-mark-transparent-png-clip-art-image-5a1c5891607da2.6430875115118071213952.jpg

ASSIGNMENT #1

- Assignment #1 is up.

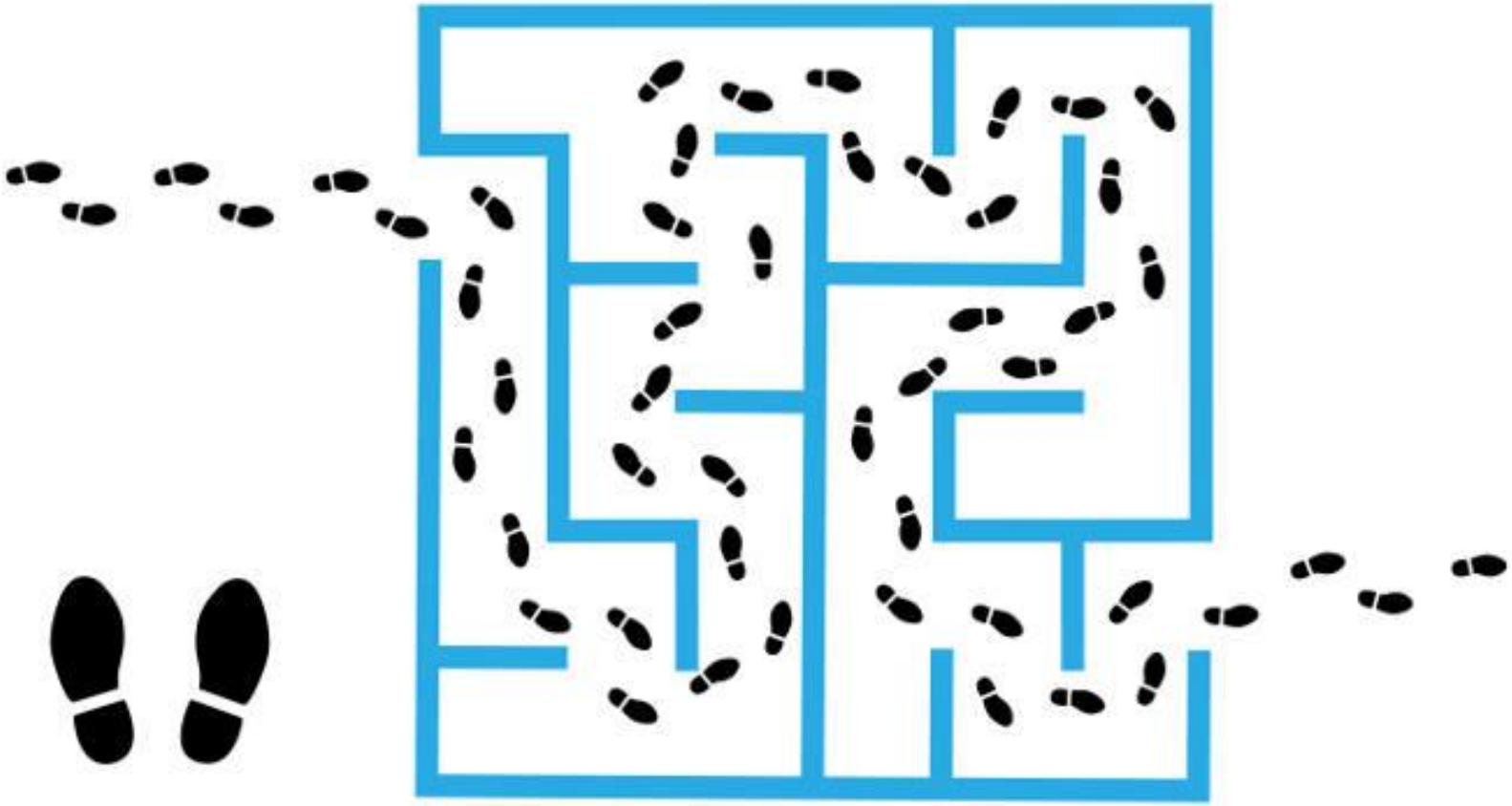
IMPORTANT!

You **must** do the SQL Injection Quiz First!

Take the quiz until you get **100%**!

https://images.emojiterra.com/mozilla/512px/1f4af.png

LAB WALKTHROUGH



https://theeducatedlandlord.com/wp-content/uploads/2019/08/Tenant-Move-In-Landlord-tenant-walkthrough.jpg